POLÍTICA INTERNA DE TECNOLOGIA E PRIVACIDADE – CORPORAÇÃO EXEMPLO S.A.

Versão: 2024.1

Classificação: Uso Interno

Área Responsável: Governança de TI e Compliance (DPO)

---

1. DIRETRIZES DE SEGURANÇA DA INFORMAÇÃO (PSI)

1.1. Armazenamento de Dados Sensíveis

Toda e qualquer aplicação que processe dados pessoais de colaboradores (biometria, rostos em vídeo, documentos de identificação) deve priorizar o armazenamento em território nacional.

- **Exceção:** É permitida a transferência internacional de dados para países que proporcionem grau de proteção de dados pessoais adequado ao previsto na LGPD (ex: União Europeia).
- **Requisito de Retenção:** Dados de mídia (fotos/vídeos) não devem ser mantidos por mais de 30 dias após o processamento original, a menos que haja base legal específica para retenção prolongada.

1.2. Criptografia e Trânsito

Dados em repouso (*at rest*) e em trânsito devem obrigatoriamente utilizar protocolos de criptografia de nível industrial (AES-256 ou superior / TLS 1.2+).

---

2. POLÍTICA DE AQUISIÇÃO DE SOFTWARE (SHADOW IT)

2.1. Homologação de Ferramentas

Nenhum software ou serviço de nuvem (SaaS) pode ser contratado sem a prévia análise do Comitê de Governança de TI. A análise baseia-se em três pilares:

1. **Segurança e LGPD:** Verificação de sub-processadores e local de armazenamento.
2. **Redundância Técnica:** Não serão aprovadas novas ferramentas que possuam mais de 80% de sobreposição funcional com softwares já licenciados pela companhia.
3. **Custo-Benefício:** Análise de viabilidade financeira pelo departamento de Compras.

2.2. Inventário de Ativos Atuais (Resumo para IA)

Atualmente, a companhia possui licenças corporativas ativas para as seguintes suítes de produtividade criativa:

- **Adobe Creative Cloud:** (Inclui Photoshop, Premiere e Firefly para geração de imagens/vídeos).
- **Canva Enterprise:** Utilizado pelo Marketing para design rápido e apresentações.
- **Microsoft 365:** Suíte oficial de produtividade.

---

3. CONFORMIDADE COM A LGPD E RELAÇÕES GOVERNAMENTAIS

3.1. Direitos do Titular

Em conformidade com a LGPD (Art. 18), a empresa deve fornecer meios para que o titular acesse, corrija ou exclua seus dados em até 15 dias úteis após a solicitação. Qualquer nova ferramenta deve possuir APIs ou métodos que permitam a exclusão definitiva de dados do usuário mediante requisição.

3.2. Documentação Governamental

A empresa atua em licitações públicas. Portanto, qualquer ferramenta que processe documentos relacionados a editais deve garantir que os dados não sejam utilizados para treinamento de modelos de linguagem de terceiros (LLMs públicos), garantindo o sigilo comercial e a integridade das propostas.

---

4. MATRIZ DE RISCO PARA FERRAMENTAS DE IA

Nível de Risco	Critério	Ação Exigida
Baixo	Armazenamento no Brasil/UE, sem uso de dados para treino.	Aprovação automática via TI.
Médio	Armazenamento fora do Brasil/UE, criptografia ativa.	Revisão manual pelo DPO.
Alto	Uso de dados do usuário para treinar modelos públicos.	**PROIBIDO.**